# LAB 5
# Static Code Analysis

## Campus Parking Permit Manager

Shashank D

SRN: PES1UG24CS433

27 October 2026

## Objective and outcome

Analyze the assigned Python program using Pylint, Bandit and Flake8, document and fix at least four issues, and verify the resulting program. Thirteen issues are documented. All final static checks pass and 18 regression tests pass.

| Check | Before | After |
|---|---|---|
| Pylint | 6.32 / 10 | 10.00 / 10 |
| Bandit | 2 Low findings | 0 findings |
| Flake8 | 16 violations | 0 violations |
| Behavioral tests | Not run on original | 18 passed |

## Submission evidence

The accompanying archive contains the cleaned script, issue table, reflection draft, original source, six analysis reports, test results, pinned dependencies and a portable Git bundle preserving three new local commits. No changes have been pushed to GitHub.

## Source and scope

SETAPESU26/L5_10_parking_permits; baseline commit 127891f607978b73040587cbb73c7a3b6bb6151a. Python 3.12.14; Pylint 4.1.3; Bandit 1.9.4; Flake8 7.4.1. Tools analyzed the assigned parking_system.py without suppressed rules.

## Issue table: correctness and security

Line references are to the original source. Medium impact is a manual assessment; Bandit reported only two Low findings and no Medium or High findings.

| Issue / type | Line(s) | Description | Fix approach |
|---|---|---|---|
| Invalid expiry accepted as valid (Manual review; Medium (assessment)) | 25-30, 59 | A malformed date is caught and returns False, allowing an expired permit. | Parse canonical ISO dates; reject invalid updates and treat unreadable expiry as expired. |
| Invalid registration data (Manual review; Medium (assessment)) | 9-15, 56-58 | Unsupported zones and blank or None plates are accepted. | Validate non-empty string plates and membership in zones A, B and C before mutation. |
| Silent database reset (Pylint W0702; Medium impact (assessment)) | 39-44 | Any load failure resets state, so corrupt data could later be overwritten. | Catch only FileNotFoundError; validate the complete loaded object before updating state; propagate other failures. |
| Predictable permit identifier (Bandit B311; Low) | 11 | random.randint uses a non-cryptographic generator and only 90,000 values. | Use secrets.token_hex(16) and check issued identifiers for collisions. |
| Exception silently ignored (Bandit B110; Low) | 20-23 | A bare except/pass hides failures during revocation. | Use dictionary pop with a default for an unknown plate. |
| Shared mutable default (Pylint W0102; Warning) | 9, 14 | zone_records=[] is shared across calls. | Use None as the default and initialize a fresh list inside the function. |

## Issue table: quality and maintainability

Line references are to the original source. Medium impact is a manual assessment; Bandit reported only two Low findings and no Medium or High findings.

| Issue / type | Line(s) | Description | Fix approach |
|---|---|---|---|
| Bare exception handlers (Pylint W0702; Flake8 E722) | 16, 22, 29, 43 | Unrestricted catches hide errors and can catch termination signals. | Remove unnecessary handlers; catch specific expected exceptions at the appropriate boundary. |
| Unmanaged file handles (Pylint R1732) | 42, 47-49 | The read handle is never explicitly closed; write closure is not exception-safe. | Use with open(...) for both reading and writing. |
| Implicit text encoding (Pylint W1514) | 42, 47 | Persistence depends on the platform default encoding. | Specify UTF-8 explicitly. |
| Missing documentation and poor naming (Pylint C0114, C0116, C0103) | 1, 9-54 | The module/functions lack docstrings; setExpiry is not snake_case. | Add docstrings and rename the function and its caller to set_expiry. |
| Global rebinding (Pylint W0603) | 40 | Loading rebinds global permits, replacing the dictionary object. | Use a named PERMITS store, validate a temporary database, then clear/update the existing object. |
| Spacing and excessive line lengths (Flake8 E302, E305, E501; Pylint C0301) | 9-68 | Top-level spacing is missing and several lines exceed limits. | Add two blank lines between top-level functions and wrap lines to at most 79 characters. |
| Import executes the demonstration (Manual review; Low (assessment)) | 68 | Importing the module prompts for input and writes a database. | Protect the entry point with if __name__ == "__main__". |

## Reflection answers - prepared draft

The supplied handout does not contain the four questions referenced in the repository. These are relevant substitute prompts, not quotations from the handout. The student should review and personalize these drafted answers.

## 1. What did the three tools contribute?

Pylint identified code quality problems such as the shared mutable default, bare exceptions, missing documentation and unsafe file handling. Flake8 identified spacing, line length and bare-except violations. Bandit identified the non-cryptographic random generator and the except/pass pattern. Their coverage overlaps, but each tool adds a different perspective.

## 2. Which issues were prioritized and why?

The original Bandit scan reported two Low-severity findings and no Medium or High findings. Both were fixed. Manual review also identified medium-impact behavior: malformed expiry dates were treated as valid, invalid registrations were accepted and load errors silently reset the database. These impact assessments are separate from tool severity. Correctness and data preservation were prioritized before documentation and formatting.

## 3. How were the fixes verified?

All three tools were run before and after the changes without disabling checks. Pylint improved from 6.32/10 to 10.00/10; Bandit fell from two findings to zero; Flake8 fell from 16 violations to zero. Eighteen regression tests passed, covering registration validation, revocation, date boundaries, zone scanning, JSON persistence, corrupt data and import behavior. A fresh demonstration run flags the expired vehicle that the original missed.

## 4. What are the benefits and limitations of static analysis?

Static analysis gives repeatable feedback early and makes code easier to review and maintain. It does not prove that business behavior is correct: the original date-format mismatch and unsupported zones needed manual inspection and behavioral tests. A clean scan should therefore be combined with tests and code review. A next improvement would be atomic file replacement and protection against simultaneous writers for production use.

## Verification and commit record

The final Pylint, Bandit and Flake8 commands each returned exit code 0. The original Pylint run produced 21 messages; Flake8 produced 16 violations. The final Flake8 report is empty because no violations were found. All raw reports are included.

## Behavior verified

Eighteen tests cover valid and invalid registrations; independent registration logs; distinct identifiers; known and unknown revocation; past and current expiry; invalid date rejection; missing and malformed expiry; zone scanning; save/load round trips; missing files; corrupt JSON; malformed database schemas; and import without prompting or writing files.

## Demonstration output

Before: Flagged in zone A: ['KA05XY9999', 'TN09QQ1111']; permits on file: 3. The expired KA01AB1234 was missed because its malformed date was treated as unexpired.

After (fresh database, Enter to skip revocation): Flagged in zone A: ['KA01AB1234', 'KA05XY9999', 'TN09QQ1111']; permits on file: 2. Only valid demonstration registrations are created.

## Three local commits

1. Fix Bandit findings: secure permit IDs and explicit exceptions.

2. Fix Pylint findings and validate permit data and expiry.

3. Fix Flake8 spacing and add lab deliverables and verification evidence.

## Reproduce and inspect

Install requirements.txt in a Python 3.12 virtual environment. Run python -m pylint --persistent=n parking_system.py; python -m bandit -r parking_system.py; python -m flake8 parking_system.py; and python -m unittest -v test_parking_system.py as separate commands.

To restore history from the archive, run git clone git_history.bundle restored_repository. Then inspect git -C restored_repository log -3 --oneline. The accompanying commit_history.txt contains the actual commit identifiers.

## Remaining limits

This lab uses local JSON storage. It does not provide transactional saving, concurrent-writer protection or jurisdiction-specific plate validation. Static-analysis success does not prove production readiness.